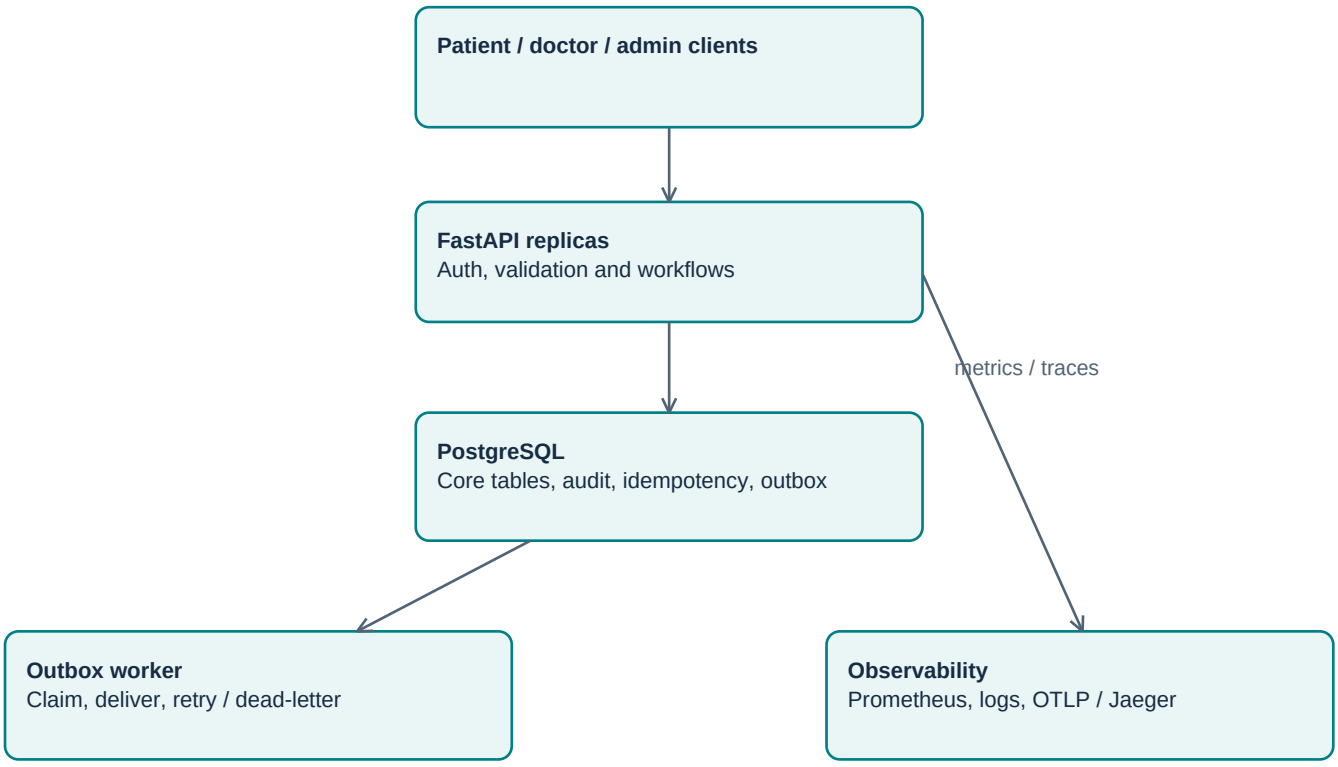
System design

01 / Deployment boundaries and data flow

A modular monolith with a durable worker

FastAPI handles typed REST routes. Request-scoped SQLAlchemy sessions and security dependencies are injected into handlers. PostgreSQL owns booking state. An independent outbox worker handles deferred delivery. Keeping booking in one database avoids distributed transaction complexity.



Implemented versus production infrastructure

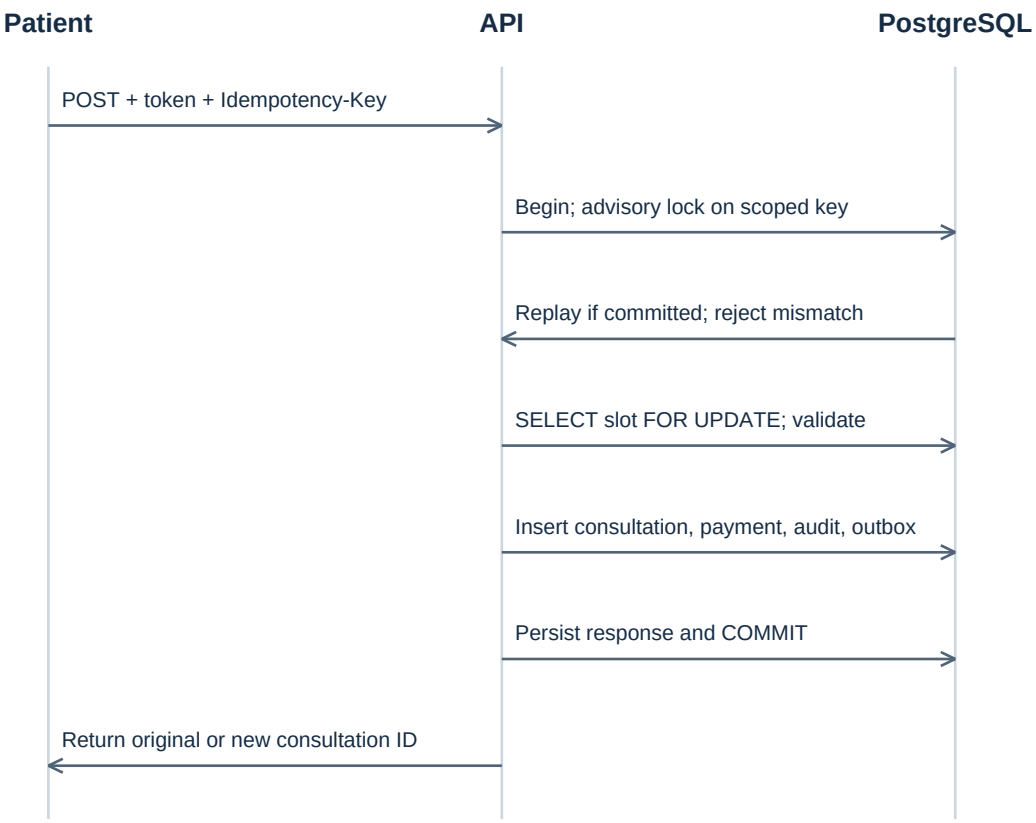
Compose runs API, PostgreSQL, bootstrap, worker, Prometheus and Jaeger on a local host. A Kubernetes template describes replicated API deployment. Production additionally needs a TLS ingress/WAF, managed multi-zone PostgreSQL, private networks, managed secrets and encrypted backups. Those components are plans, not deployed guarantees.

API and integration boundaries

Swagger UI and a generated OpenAPI contract expose registration/login/MFA, doctor search, availability, bookings, consultation state, prescriptions and admin reporting. The payment table tracks a pending/cancelled ledger. Notification delivery is a synthetic log adapter. No live funds, email, video calls or clinical decisions are performed.

Booking correctness

Booking sequence



Independent integrity safeguards

The slot row lock serializes competing bookings. A partial unique index on slot_id for every non-cancelled consultation prevents two active bookings even if an application check fails. A per-doctor advisory lock plus overlap query protects availability creation. Database constraints and application checks serve different purposes.

Durable response replay

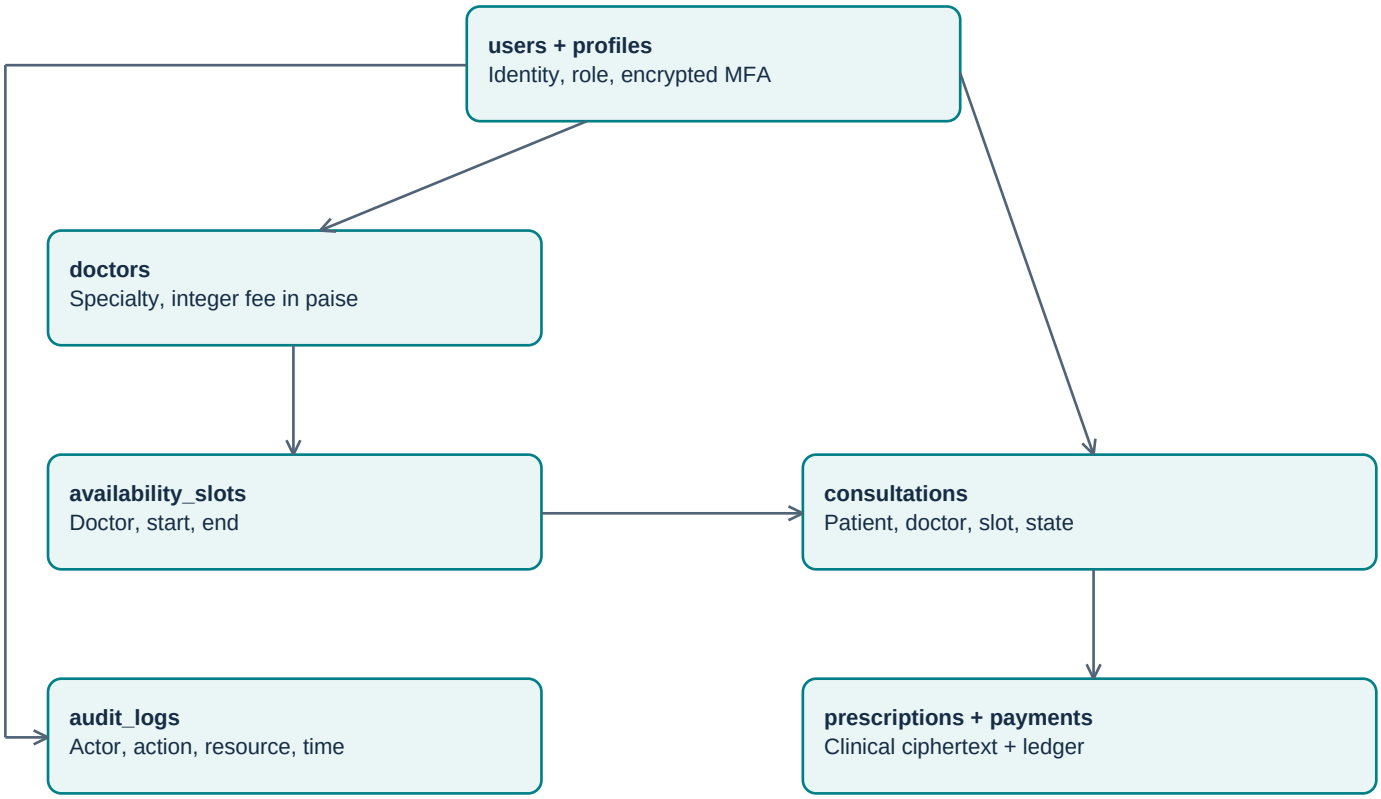
Each domain mutation requires a client-generated key. A SHA-256 request fingerprint covers the operation and body. A transaction advisory lock serializes identical keys. The response, domain mutation, audit and outbox commit together. Same key/body returns the original response; different body returns 409. MFA replay responses are encrypted; no plaintext clinical body is stored in replay data.

State and failure rules

booked -> in_progress -> completed; booked -> cancelled. Only the assigned doctor progresses a consultation or writes a prescription. Completion requires a prescription. Cancellation releases the active-slot constraint. Failed transactions roll back all associated changes. Retry transient failures with the same key, bounded exponential backoff and jitter.

Data and security

Core entity relationships



A slot has consultation history but at most one non-cancelled booking. A consultation has at most one immutable prescription and one payment ledger. Support tables store idempotency keys, rate buckets and outbox jobs.

Authorization and credential controls

Public registration always creates a patient. Initial admin promotion is an operator CLI action; doctor provisioning is admin-only and requires the target to enable MFA. Passwords use Argon2. Signed JWTs verify algorithm, expiry, issuer, audience and subject. Doctor/admin requests require a verified-MFA token. Accepted TOTP time steps are locked and cannot be replayed.

Clinical protection and audit

Only consultation participants can read clinical records; admin reporting has no prescription access. Prescriptions and MFA seeds use authenticated Fernet encryption. Logs avoid tokens, emails and clinical payloads. Audit events commit with domain writes; a PostgreSQL trigger denies row update/delete. Production requires TLS, disk/backups encryption, KMS, a non-owner DB role and an external tamper-evident audit sink.

Reliability and scale

Capacity and latency objectives

100,000 consultations/day averages about 1.16 new consultations/second. A 20x peak assumption implies roughly 23 bookings/second plus reads and lifecycle traffic. p95 targets are reads below 200 ms and writes below 500 ms. These are design objectives, not measured outcomes. Functional tests do not prove throughput or uptime.

Indexes cover slot doctor/time, consultation participants/state, doctor specialty and audit time. Page sizes are bounded. Use cursor pagination for deep histories and precomputed reporting aggregates at scale. No Redis cache is active: a future short-TTL public directory cache must never decide reservation correctness.

Partitioning and availability

Partition audit and delivered-outbox history by month only when measurements justify it. Date-partitioned consultations must retain global active-slot uniqueness, for example through a separate slot reservation table. Scale stateless API and worker replicas independently; tune DB connection budgets. 99.95% availability permits about 21.6 minutes of downtime per 30-day month and requires multi-zone infrastructure and tested failover.

Outbox retries and proposed payment saga

Workers claim rows using FOR UPDATE SKIP LOCKED, retry with exponential backoff plus jitter, cap delay at one hour, and move to dead state after eight failures. Delivery is at-least-once: a real provider must deduplicate stable outbox IDs. A proposed real-payment saga holds a slot, requests payment, verifies a signed webhook, then confirms; failure releases the hold and refunds captured funds. This saga is not implemented in the demo ledger.

Backup, recovery and key rotation

Proposed RPO <=5 minutes and RTO <=60 minutes need encrypted daily backups, continuous WAL/PITR, offsite immutable copies and quarterly restore drills. Back up encryption keys separately. Restore into an isolated database, verify counts/uniqueness/audit and decryption, then run a synthetic workflow before switching traffic. No restore or HA drill was executed here.

JWT rotation supports one previous signing secret during token expiry. Fernet reads support multiple keys and writes use the first. Reencrypt stored ciphertext before removing old keys. Production also needs verified account recovery, session revocation, consent/retention workflows and jurisdiction-specific clinical/legal review.

Observability and evidence

Prometheus exports request counts and latency histograms; alerts cover availability, errors and slow reads/writes. JSON logs contain correlation IDs. OTLP traces export to Jaeger. CI runs PostgreSQL tests, security scans and an image build. See VERIFICATION.md for executed checks and explicitly unverified integration/deployment items.